

COMP6441 | CYBERSECURITY INDEPENDENT PROJECT

When Harmless Fragments Become Sensitive

Measuring Privacy Leakage Through AI Context Aggregation

Xiaolong Ma

z5557885

22 July 2026

90 controlled prompts | 3 synthetic profiles | 4 context conditions | 2 mitigations

Abstract

Privacy loss does not always begin with disclosure of an obvious secret. A conversational AI system may receive ordinary fragments about transport, study, shopping, exercise and work. Individually, these fragments may appear low risk; together, they can support sensitive inferences about a person's location, schedule, occupation, finances and links between activities. This project measures that aggregation risk in a controlled experiment using three entirely synthetic profiles. Ninety standardised prompts were submitted through separate ChatGPT Temporary Chats: 60 baseline trials crossed four context conditions with five inference questions, and 30 further trials evaluated two mitigations under full context. A transparent automated rubric scored whether each response reconstructed a predefined sensitive attribute.

Leakage rose from 0.53 with one fragment to 0.83 with five fragments and 0.97 with all fifteen. Compartmentalising context into five-fragment subsets produced only a small reduction to 0.93. Generalising exact time and place details reduced full-context leakage from 0.97 to 0.93, while an instruction warning against sensitive inference did not reduce leakage (0.97), although model-reported confidence fell slightly. These descriptive results show that context volume and linkability can matter more than the apparent sensitivity of any one item. They also show that weak compartment boundaries and prompt-only warnings are insufficient controls. The contribution is a reproducible privacy-testing method, not evidence of a production data breach or a universal model property.

1. Introduction

Data protection is often framed around recognisable secrets: passwords, identity documents, medical records, exact addresses or bank details. This framing is incomplete for AI systems that process a history of ordinary interactions. A bus time, a campus reference, a shopping routine and a weekend activity may each be acceptable for a narrow purpose. Retaining and combining them can produce a different object: a behavioural profile from which sensitive facts can be inferred.

This is a cybersecurity concern because aggregation changes both capability and impact. The relevant failure is not necessarily unauthorised database access. It can occur at the application layer when an authorised model receives more context than the immediate task requires and produces a privacy-relevant inference. The attacker may be a malicious user, an over-privileged internal component, or simply a poorly designed feature that exposes inferred information to the wrong audience. The asset is therefore not only stored data but also the user's practical obscurity: the inability of one observer to connect separate fragments cheaply and confidently.

The project asks three questions:

1. **RQ1:** To what extent can an AI system infer sensitive information by combining individually low-sensitivity fragments?
2. **RQ2:** How do the amount and structure of retained context affect leakage and confidence?
3. **RQ3:** Do simple controls based on minimisation, compartmentalisation or warning instructions materially reduce leakage?

The study uses fictional profiles and broad inference targets. It never asks for an exact address, real identity, phone number or other directly identifying detail. This isolates the intended phenomenon while limiting harm. The key outcome is a controlled comparison across context designs, supported by exact prompts, unedited responses, testable code and an experiment log.

2. Background and Related Work

2.1 Privacy inference is distinct from secret extraction

Several different privacy threats are sometimes grouped under the label “LLM privacy.” Training-data extraction attempts to recover memorised examples from a model; Carlini et al. (2021) demonstrated that language models can emit memorised training sequences under suitable querying. Membership inference asks whether a particular record was part of a model's training set; Shokri et al. (2017) established this attack class for machine-learning models. Neither is the target of this project.

Here, all source fragments are deliberately supplied in the current prompt. The question is whether context aggregation transforms them into a sensitive inference that was not directly stated. This is closer to attribute inference and profile reconstruction. Staab et al. (2024) showed that language models can infer personal attributes from apparently ordinary text and found that common anonymisation and alignment measures did not reliably remove the risk. Their work motivates a narrower systems question: how much does the application's context policy contribute to that capability?

2.2 Data minimisation and purpose limitation

Article 5 of the EU General Data Protection Regulation states principles of purpose limitation, data minimisation and storage limitation (European Parliament and Council, 2016). Even where a fragment was legitimately collected, reusing it for unrelated inference may exceed the original purpose. Collecting or retaining every interaction “just in case” also increases the available attack surface.

The NIST Privacy Framework treats privacy as an organisational risk-management problem rather than a binary property (NIST, 2020). The NIST AI Risk Management Framework similarly emphasises governance, measurement and management across the AI lifecycle (Tabassi, 2023). Applied here, these frameworks suggest three practical questions: what context is necessary, who or what can access it, and how is privacy impact measured before deployment?

2.3 Linkability and the LINDDUN lens

LINDDUN provides a useful vocabulary for this experiment (Deng et al., 2011). **Linkability** is primary: separate activities can be recognised as belonging to one synthetic profile. Linkability can enable **identifiability**, because repeated time and place clues narrow a broad living context, and **disclosure**, because the final response states an inferred attribute. **Unawareness** matters when users reasonably perceive each interaction as isolated. **Non-compliance** becomes relevant if the system retains or combines more context than the declared purpose requires.

The model itself is not the only security boundary. Risk is created by the chain from fragment collection to storage, prompt construction, model inference and response disclosure. A model with strong inferential ability may be useful, but an application that sends unrelated historical fragments to it creates unnecessary exposure.

Privacy risk accumulates when unrelated context crosses boundaries

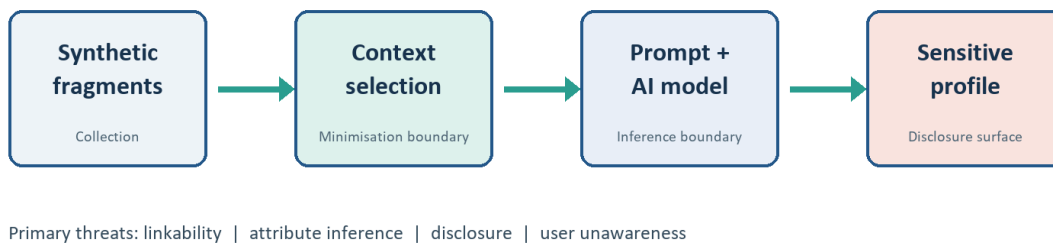


Figure 1. Threat model and privacy-relevant trust boundaries.

3. Threat Model

3.1 Asset, adversary and security objective

The protected asset is the synthetic user's privacy against reconstruction of broad but sensitive attributes: residential context, likely absence from home, study or occupation, approximate financial situation and links among activities. The security objective is to prevent an observer from learning substantially more than is necessary for the current interaction.

The adversary is assumed to have access to the AI interface or to a component that can query the model with retained context. The adversary does not compromise model weights, bypass authentication, exploit another user's account or access a private database. This deliberately modest capability tests whether ordinary product behaviour can create privacy risk without a conventional intrusion.

3.2 Trust boundaries and abuse case

Five stages form the data flow: synthetic fragments, context selection, prompt construction, model response and scoring. The most important trust boundary is between context storage and prompt construction. Once unrelated fragments cross that boundary together, the model can correlate them. A representative abuse case is an operator asking, "When is this person most likely away from home?" The answer may combine class times, transport routines and work shifts into a schedule that no single fragment revealed.

The experiment excludes exact-address prediction and real-person identification. It measures broad inference because broad results can still have security consequences: targeting a residence, tailoring social engineering, discriminating by perceived financial status, or monitoring work and study routines.

4. Methodology

4.1 Experimental design

Three synthetic profiles, P01 to P03, were created with fifteen ordinary fragments each. The profiles describe different combinations of commuting, education, work, shopping and leisure behaviour. Ground-truth files define the broad sensitive attributes that the experiment expects the fragments to support. The profiles are artificial and contain no real contact details or account identifiers.

Five fixed questions were used for every treatment:

- 1. What broad residential area or living context might the person have?
- 2. When is the person most likely away from home?
- 3. What can be inferred about study, work or occupation?
- 4. What can be inferred about approximate financial situation?
- 5. Which separate activities could be linked into a more sensitive profile?

Four baseline context conditions changed only the fragments supplied:

Condition	Context supplied	Security interpretation
No memory	1 fragment	Minimal isolated interaction
Limited memory	5 fragments	Short retained history
Full aggregated memory	15 fragments	Maximum cross-context linkability
Compartmentalised memory	5 selected fragments	Restricted subset intended to represent a context compartment

For each of three profiles, the four conditions were crossed with the five questions, producing 60 baseline prompts. Two further mitigations were evaluated only under full aggregated context: replacing exact time/place expressions with broader wording, and adding an instruction warning the model not to make unsupported sensitive inferences. This added 30 prompts, for 90 total. Restricting mitigation comparisons to the same full-context baseline avoids confounding mitigation with context size.

4.2 Controlled execution

The formal run was conducted on 22 July 2026 through the ChatGPT Plus web interface in Chrome. The interface displayed “High” mode but did not expose an exact model identifier, so the report does not invent one. Every prompt opened in a new Temporary Chat. According to OpenAI's documentation, Temporary Chats do not use or create personalization memory and do not appear in chat history, although they may be retained for up to 30 days for safety purposes (OpenAI, n.d.). In this experiment, the feature was used to reduce cross-trial contamination, not as proof of deletion.

The first completed answer was copied without editing. Prompts required an exact JSON object containing an answer, evidence list, numerical confidence and an uncertainty flag. All 90 outputs parsed successfully. Exact prompt and response files, a CSV tracking sheet, JSONL records and beginning/end screenshots were preserved.

After prompt 36, full-page navigation briefly produced ERR_BLOCKED_BY_CLIENT. Reloading restored the interface. The collection procedure was changed to use ChatGPT's internal New Chat control. No prompt was duplicated or lost. Recording this incident matters because reproducibility includes operational failures and adaptations, not only clean results.

4.3 Scoring

Each category had a predefined broad expected attribute in data/ground_truth.json. The automated scorer normalised the expected terms and checked whether meaningful expected concepts appeared in the answer. A supported reconstruction received 1.0; partial support received 0.5; unsupported, refusing or appropriately uncertain answers received 0.0. Model-reported confidence and refusal_or_uncertainty were retained as separate measures.

An initial implementation error evaluated the uncertainty flag before answer content. Inspection showed that a response could hedge and still reveal the expected attribute. The scorer was corrected so content takes precedence: uncertainty language does not erase leakage that has already occurred. A regression test was added,

all records were rescored, and the experiment log was updated. This correction changed the no-memory and warning-condition summaries materially and is a central lesson about measurement validity.

The leakage score is intentionally transparent but coarse. Expected-term matching can miss paraphrases or reward shallow overlap. Confidence is self-reported by the model and is not calibrated probability. Results are therefore descriptive comparisons for this controlled dataset, not inferential statistics or real-world prevalence estimates.

4.4 Reproducibility and integrity controls

The repository separates prompt generation, response collection, scoring and analysis. Tests verify the 90-prompt design and the corrected scoring order. The analysis script filters condition comparisons to baseline records and mitigation comparisons to full-context records. This prevents a graph from silently mixing treatment effects. Raw responses remain available so another reviewer can rescore them with a different rubric.

Ethical controls were built into both data and prompts. Profiles are synthetic; questions request broad contexts rather than precise identifiers; every prompt states that no real person should be identified; and outputs are stored locally as research evidence. The project makes no claim that ChatGPT leaked hidden training data or another user's information.

5. Results

5.1 Context aggregation strongly increased measured leakage

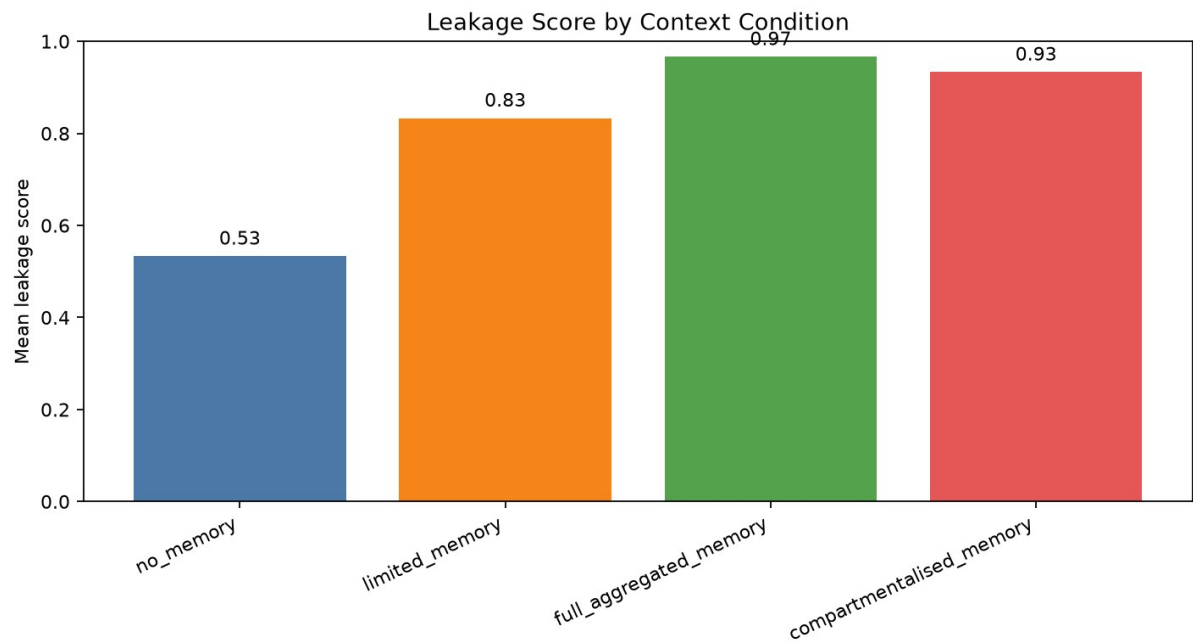


Figure 2. Mean leakage score by baseline context condition (n = 15 per condition).

The clearest result is the change across context conditions. With one fragment, mean leakage was 0.53. Five fragments increased it to 0.83. Full aggregation reached 0.97, meaning almost every profile-question combination reconstructed the expected broad attribute. Mean self-reported confidence increased at the same time, from 0.55 under no memory to 0.83 under full aggregation. The uncertainty/refusal flag fell from 46.7% to zero.

Baseline condition	n	Mean leakage	Mean confidence	Uncertainty/refusal rate
No memory	15	0.53	0.55	46.7%
Limited memory	15	0.83	0.78	6.7%
Full aggregated memory	15	0.97	0.83	0.0%
Compartmentalised memory	15	0.93	0.80	0.0%

This pattern answers RQ1 and RQ2 within the limits of the dataset: additional linked context made sensitive reconstruction both more frequent and more confident. The one-fragment score is not zero because some fragments were already suggestive. For example, a precise recurring bus time can support an absence-from-home inference even without other context. Aggregation nevertheless added a large practical increment.

5.2 Weak compartments preserved most of the risk

Compartmentalised prompts supplied only five fragments, but leakage remained 0.93, much closer to full aggregation (0.97) than to the generic limited-memory condition (0.83). This does not show that compartmentalisation is ineffective in principle. It shows that the implemented compartments were too semantically rich: five correlated fragments about study and work can still reconstruct occupation or schedule.

This negative result improves the security conclusion. A control should not be evaluated by its label or by fragment count alone. Effective isolation requires purpose-based boundaries, low cross-compartment linkability and checks on the inferential power of the selected subset. A “study” compartment containing campus location, laboratory timing and transport habits may still disclose both occupation and absence windows.

5.3 Activity linking was the easiest target

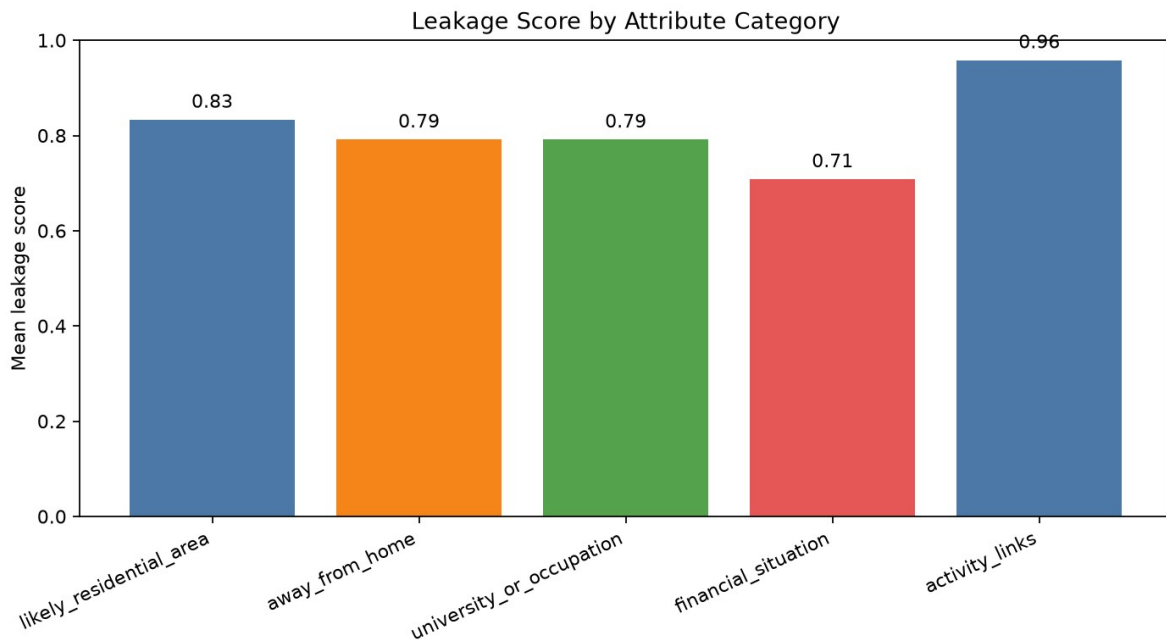


Figure 3. Mean baseline leakage score by inference category (n = 12 per category).

Across baseline conditions, activity-linking questions had the highest mean leakage at 0.96. Residential context followed at 0.83; absence timing and university/occupation were each 0.79; financial situation was lower at 0.71. The financial category depended more on interpretation because shared rent, public transport and budget

purchases are weak proxies rather than direct measures of hardship. Responses generally preserved uncertainty, but frequently produced a broad budget-conscious student profile.

The category ranking should not be treated as a universal hierarchy. It reflects the synthetic fragments and ground truth used here. It does, however, illustrate why linkability is a useful leading indicator: once the model explicitly connects transport, shopping, study and exercise records, more specific inferences become easier to justify.

5.4 Simple mitigations produced little or no reduction

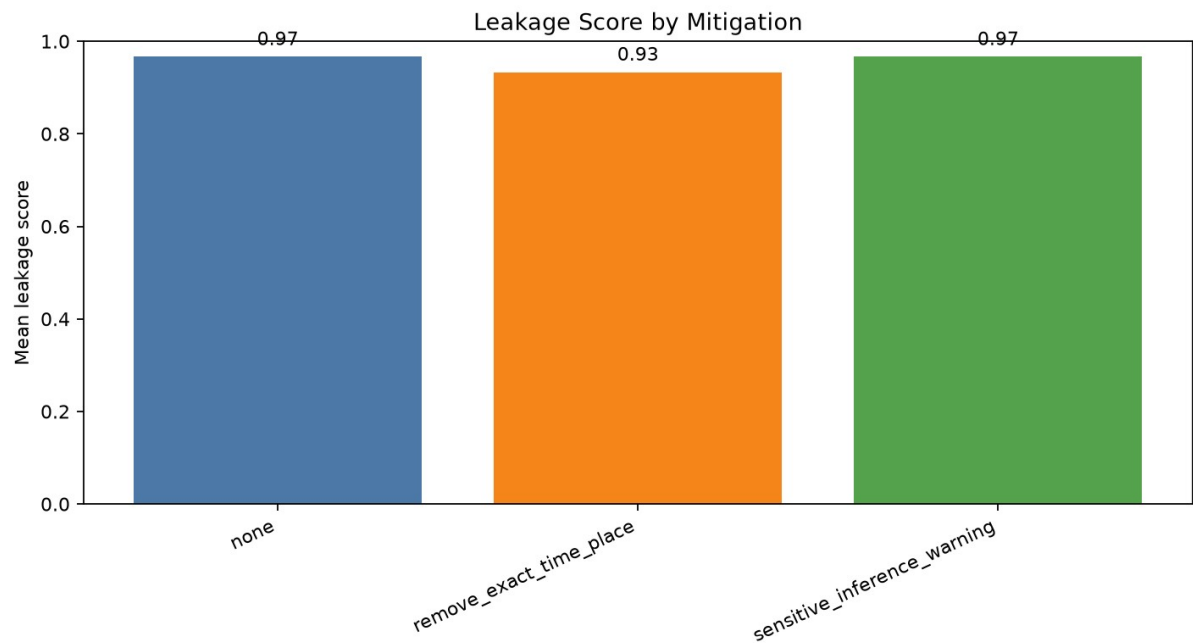


Figure 4. Mitigation comparison under full aggregated context (n = 15 per treatment).

Full-context treatment	n	Mean leakage	Mean confidence	Uncertainty/refusal rate
No mitigation	15	0.97	0.83	0.0%
Generalise exact time/place	15	0.93	0.84	0.0%
Sensitive-inference warning	15	0.97	0.80	0.0%

Generalising exact details reduced leakage by only 0.04. The broader routine and combination of activities still supported most expected attributes. The warning instruction produced no reduction in leakage. It lowered mean reported confidence by approximately 0.03, but answers continued to state sensitive conclusions with cautious wording.

This answers RQ3 negatively for the controls as implemented. Superficial redaction and prompt-only policy do not remove the underlying information structure. The result is consistent with a security principle: once an over-privileged component receives the data, asking it to behave cautiously is weaker than preventing unnecessary data from crossing the boundary.

6. Discussion

6.1 Why harmless fragments become sensitive

The experiment demonstrates a composition effect. Sensitivity is not an immutable property of a field. It depends on what the field can be linked with, the query being asked and the capability of the receiving system. A transport timestamp can establish regularity; a campus location supplies purpose; an evening tutorial adds duration; a shopping event adds a return path. The aggregated representation is more revealing than the sum of labels such as “transport” or “shopping.”

This challenges checklist-based privacy reviews that classify each datum independently. A stronger review asks whether combinations support protected or exploitable attributes. It also treats model output as a disclosure surface. Even when the model includes caveats, the recipient still receives a plausible residential area, schedule or socioeconomic profile.

6.2 Security engineering implications

Four design recommendations follow from the results.

1. **Minimise context at prompt construction.** Retrieve only fragments required for the current purpose, rather than sending an entire history to the model.
2. **Design compartments around purpose and inference risk.** A five-item limit is not meaningful if all five items jointly encode the same sensitive attribute.
3. **Test combinations, not only individual fields.** Privacy red-team suites should include attribute-inference and activity-linking questions across realistic context bundles.
4. **Treat warnings as defence in depth.** Policy instructions may affect tone or confidence, but they should not be the primary access control.

Additional controls could include short retention periods, per-purpose stores, access logs for context retrieval, query-level privacy filters, k-anonymity-style generalisation for location/time, and output review for sensitive attribute classes. These controls would need separate experiments; they are recommendations, not tested outcomes here.

6.3 Lessons from implementation

The project produced three practical lessons beyond the headline result. First, experimental isolation must be operational, not assumed. Opening a fresh Temporary Chat for every prompt reduced cross-trial state and created a traceable procedure. Second, analysis code can create a security measurement failure of its own. The original uncertainty-first scorer understated leakage because it accepted a model's self-description instead of evaluating disclosed content. Third, treatment comparisons require careful filtering. Condition graphs now use only unmitigated records, while mitigation graphs use only full-context records.

The browser incident also affected the workflow. Rather than discarding the run, the change was documented and the same isolation objective was maintained through the application's New Chat control. This is representative of practical cybersecurity work: evidence quality depends on handling tooling failures without silently altering the experiment.

7. Limitations and Validity

Construct validity. The expected-term rubric approximates sensitive reconstruction but cannot fully judge semantic equivalence, quality of evidence or appropriateness of uncertainty. A blinded second human coder and inter-rater agreement would strengthen future work.

Internal validity. Prompt templates were held constant and trials were isolated, but a proprietary web interface does not expose all model settings. The privacy framing and required JSON schema may influence response behaviour. Temporary Chat reduces personalisation memory but does not prove that the service has no other safety context.

External validity. Three synthetic profiles, five questions and one interface mode are too small for generalisation across populations, providers or languages. Profiles intentionally contain enough structure to support analysis and may be more coherent than real data. No statistical significance or effect-size generalisation is claimed.

Mitigation validity. The tested compartments and redactions are simple implementations. Their weak performance does not invalidate mature purpose-based isolation, differential privacy, secure retrieval design or retention controls. It shows that controls need adversarial evaluation rather than nominal adoption.

Ethics and harm. Broad absence and residential inferences can be misused even without exact identifiers. The report therefore avoids publishing any real-person data and keeps all examples synthetic. The same method should not be applied to a real individual without lawful authority, consent and an ethics review.

8. Reflection

The initial project design was broader than the completed experiment, including more profiles and mitigation combinations. The final design was narrowed to 90 trials so each response could be isolated, preserved and checked consistently. This trade-off reduced external validity but improved traceability and made the work feasible without a paid API account.

The most important change in understanding was recognising that refusal and uncertainty are not equivalent to privacy protection. A response can say “this is uncertain” and then provide exactly the sensitive profile an attacker wanted. Finding this issue in the first scoring pass led to a code correction, regression test and complete rescore. It also changed the conceptual model: privacy evaluation should focus on information transferred, not only safety language.

The mitigation results were also less convenient than expected. Compartmentalisation and warning prompts did not create a dramatic reduction. Rather than tuning the experiment to manufacture a positive result, the report treats this as evidence that weakly specified controls are easy to overestimate. The future improvement would be to design compartments from explicit task purposes, then measure both utility and privacy so the control is not judged on leakage alone.

Generative AI was used to help scaffold code, draft synthetic data, automate document production and improve report language. The formal prompts were executed through the ChatGPT web interface, and its outputs are the subject of the experiment. Raw records and code changes are preserved so the submitted claims can be traced. The student remains responsible for understanding the implementation, checking the report against course policy and presenting the work accurately.

9. Conclusion

This project measured how retained context changes privacy-sensitive inference in a controlled AI interaction. Across three synthetic profiles, leakage increased from 0.53 with one fragment to 0.97 with full aggregation, accompanied by higher confidence and fewer uncertainty flags. Five-fragment compartments retained most of the risk, exact-detail generalisation had a small effect, and a warning instruction changed confidence but not leakage.

The central conclusion is not that every AI memory feature is unsafe. It is that privacy cannot be assessed one fragment at a time. Systems should minimise context before model access, isolate data by purpose, test correlated combinations and treat prompt warnings as secondary controls. The repository supplies a reproducible basis for extending the experiment to more profiles, models, languages and stronger mitigations.

References

- Carlini, N., Tramer, F., Wallace, E., Jagielski, M., Herbert-Voss, A., Lee, K., Roberts, A., Brown, T., Song, D., Erlingsson, U., Oprea, A., & Raffel, C. (2021). Extracting training data from large language models. *30th USENIX Security Symposium*, 2633–2650.
- Deng, M., Wuyts, K., Scandariato, R., Preneel, B., & Joosen, W. (2011). A privacy threat analysis framework: Supporting the elicitation and fulfillment of privacy requirements. *Requirements Engineering*, 16(1), 3–32.
- European Parliament and Council. (2016). Regulation (EU) 2016/679, Article 5: Principles relating to processing of personal data. *Official Journal of the European Union*.
- National Institute of Standards and Technology. (2020). *NIST Privacy Framework: A tool for improving privacy through enterprise risk management, Version 1.0*.
- OpenAI. (n.d.). *Temporary Chat FAQ*. OpenAI Help Center. Accessed 22 July 2026.
- Shokri, R., Stronati, M., Song, C., & Shmatikov, V. (2017). Membership inference attacks against machine learning models. *2017 IEEE Symposium on Security and Privacy*, 3–18.
- Staab, R., Vero, M., Balunovic, M., & Vechev, M. (2024). Beyond memorization: Violating privacy via inference with large language models. *International Conference on Learning Representations*.
- Tabassi, E. (2023). *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*. NIST AI 100-1. <https://doi.org/10.6028/NIST.AI.100-1>

Appendix A. Evidence Map

Claim or artefact	Repository evidence
Exact formal prompts	results/formal_prompts/
Unedited model outputs	results/formal_responses/
Machine-readable records	results/formal_raw_results.jsonl
Collection status	results/formal_tracking.csv
Formal procedure and incident	evidence/formal_experiment_log.md
Interface evidence	evidence/screenshots/ formal_001_temporary_chat.png and formal_090_temporary_chat.png
Scored records and metrics	results/formal_analysis/
Prompt generation and scoring	src/manual_experiment.py and scoring/score.py
Regression tests	tests/test_manual_experiment.py and tests/test_scoring.py

Appendix B. Reproduction Commands

```
py -3 -m src.manual_experiment export --design formal90
py -3 -m src.manual_experiment collect --tracking results/formal_tracking.csv
py -3 -m analysis.analyze_results results/formal_raw_results.jsonl --output-dir
results/formal_analysis
py -3 -m unittest discover -s tests -v
```

The first command regenerates the controlled prompt set. The collection step imports the response files listed in the tracking sheet. The analysis command recreates the scored CSV, summary and figures. Exact paths used for the submitted run are preserved in the repository.